

CertifEye AD CS ESC Audit Report

CertifEye - Active Directory Certificate Services defensive review

Prepared for	Current audit dataset
Date	2026-06-30
Scope	Scrubbed AD CS exports — issuance + posture; no authentication-use logs assumed
Data analyzed	16,800 certificate rows · 48 templates · 84 PKI ACEs · 1 CA row(s) · 12 DC row(s) · 4 web endpoint row(s) · 64 high-value token(s)
Overall posture	CRITICAL — one or more critical AD CS paths require validation/remediation

Read first. Issued-certificate evidence proves a certificate was *issued* — not that it was used to authenticate. Confirmation requires DC/Kerberos certificate-authentication logs. Posture findings describe conditions that can enable abuse, not proof that abuse occurred. Every remediation item is advisory and should be validated by a PKI administrator.

Executive Summary

Overall verdict

The highest-priority issues in this dataset are: F01-ESC1 (Critical; Likely ESC1 misuse); F02-ESC3 (Critical; Suspicious issuance needing validation); F03-ESC5 (Critical; Template / PKI posture issue). Treat issuance evidence as proof of issuance only until authentication-use logs confirm use.

Findings by severity and category

Severity	Critical	High	Medium	Low
Count	6	7	2	0

Category	Count
Likely ESC1 misuse	2
Suspicious issuance needing validation	4
Template / PKI posture issue	9

Top risks

- F01-ESC1 · Critical

6 certificate issuance row(s) on template 'TPL_24152c08622d161118179073' have identity mismatch status DifferentMappedIdentity; 6 joined to template inventory, 6 are authentication-capable, and 6 involve HV/high-value tokens; first=2023-07-01, last=2024-06-30, revoked=0/6. Sample RequestIDs: REQ_3e94596bfd4d8bfe1427236b;REQ_5229509cf6e8e5c183c4367f;REQ_6805b4e213cb4f3331fab340;REQ_a2bac1578097a5f4681d0727;REQ_d37abbc6f8e3ef9d1852f9e1;REQ_ec7fc769ed23736f684d2fe5.

- F02-ESC3 · Critical

12 certificate row(s) carry the Certificate Request Agent ECU and 14 on-behalf-of row(s) show caller/requester differences; high-value OBO rows: 5; first=2023-09-09, last=2026-06-28, revoked=0/14.

- F03-ESC5 · Critical

4 dangerous PKI-object ACE(s) for PRINCIPAL_46ee1a5d4c288f103379be2e: object types CertificationAuthoritiesContainer, EnrollmentServiceCA, EnrollmentServicesContainer, NTAAuthCertificates; rights include GenericAll, GenericWrite, WriteDacl, WriteOwner. Enroll-only rights were not counted as ESC5 control.

- F04-ESC6 · Critical

CA configuration indicates EDITF_ATTRIBUTESUBJECTALTNAME2 / ESC6_CAConfigFlag is enabled.

- F05-ESC6 · Critical

10 issued certificate row(s) include SAN request attributes on joined templates that do not allow requester-supplied Subject/SAN; first=2024-04-14, last=2026-01-31, revoked=0/10. Sample RequestIDs: REQ_1f1a1a58b8f75433d9ca5fe9;REQ_34bd8b68a53f21ac62d25b0d;REQ_556fc60639e9f197fd24f65b;REQ_689f40b3f258776425c056cd;REQ_9432c7ebc26dd907f9824278;REQ_a5299656756b727a0167a9e1;REQ_c41fbebef217c4a5ef665533;REQ_d9891de883b0509ca6494c90.

Prioritized recommendations

- **Validate F01-ESC1.** Correlate the certificate serials/thumbprints or RequestIDs with DC/Kerberos certificate-authentication logs before claiming confirmed misuse.

- **Remediate F01-ESC1.** If unexplained, revoke the certificates and tighten the issuing template's subject/SAN, approval, signature, and enrollment settings.

- **Validate F02-ESC3.** Confirm all enrollment agents are authorized and that CA Enrollment Agent restrictions limit which templates and principals they can request for.

- **Remediate F02-ESC3.** Restrict enrollment-agent template enrollment, configure CA Enrollment Agent restrictions, and require authorized signatures on sensitive templates.

- **Validate F03-ESC5.** Confirm whether the principal is an approved PKI/tier-0 administrator and whether each listed ACE is intentional.

Remediation Guide

Every step below is advisory. Validate ownership and business need before making PKI changes.

ESC1

Templates let requesters name the certificate identity

Severity: Critical · 3 finding(s)

What it is. A published authentication-capable template allows the requester to supply the subject or SAN.

How it can be abused. A requester can ask for a certificate naming a different account when enrollment scope and approval controls permit it.

How to fix it.

1. Open Certificate Templates (certtmpl.msc) and identify every flagged published template.
2. On Subject Name, select Build from this Active Directory information unless requester-supplied identity is required.
3. If requester input is required, enable CA manager approval or require authorized signatures.
4. On Security, restrict Enroll and Autoenroll to the smallest approved group; remove broad/default enrollment.
5. Revoke and reissue affected certificates when validation confirms inappropriate issuance.

How to verify. Re-export templates and issuance. Confirm requester-supplied subject/SAN is disabled or approval/signature controls are present, and review remaining mismatches.

ESC3

Enrollment-agent and on-behalf-of issuance needs tight restriction

Severity: Critical · 1 finding(s)

What it is. Enrollment Agent capability permits approved identities to request certificates on behalf of others.

How it can be abused. An over-broad agent population or missing agent restrictions can allow unauthorized delegated issuance.

How to fix it.

1. Inventory every Enrollment Agent certificate and validate its owner, purpose, validity, and revocation state.
2. Configure CA Enrollment Agent restrictions to limit which agents may use which templates for which subjects.
3. Restrict Enrollment Agent template enrollment and require authorized signatures where appropriate.
4. Remove stale agents and revoke certificates that no longer have an approved owner or purpose.

How to verify. Re-export agent and on-behalf-of issuance; confirm every agent is approved and CA restrictions cover its permitted templates and subjects.

ESC5

Loose permissions on core PKI directory objects

Severity: Critical · 1 finding(s)

What it is. Core Public Key Services objects determine trusted CAs, enrollment services, and available certificate templates.

How it can be abused. Write or ownership control can alter enterprise trust or PKI publication. Enroll-only rights and a CA host controlling its own CA object are not treated as control.

How to fix it.

1. Open ADSI Edit and navigate to Configuration -> CN=Public Key Services,CN=Services.
2. For each flagged object, open Properties -> Security and confirm the principal's approved role.
3. Remove GenericAll, GenericWrite, WriteDacl, WriteOwner, or equivalent control from non-PKI administrators and broad principals.
4. Retain the CA computer account on its own CA object only when required and documented.
5. Review parent-container inheritance so removed access is not reapplied.

How to verify. Re-export PKI object ACLs; confirm dangerous control ACEs for non-administrative principals are gone.

ESC6**CA-wide SAN request attributes can override template intent**

Severity: Critical · 2 finding(s)

What it is. EDITF_ATTRIBUTESUBJECTALTNAME2 permits SAN values from request attributes across the issuing CA.

How it can be abused. A template that appears to build identity from AD may still accept requester-controlled SAN data through the CA-wide flag.

How to fix it.

1. Confirm the live EditFlags value on every issuing CA and document any application dependency.
2. Remove EDITF_ATTRIBUTESUBJECTALTNAME2 when it is not explicitly required.
3. Where removal is delayed, restrict enrollment, require approval, and monitor SAN request-attribute issuance.
4. Restart Certificate Services during an approved maintenance window after changing the flag.

How to verify. Re-read the live CA flag and issue an approved validation request that confirms unauthorized SAN request attributes are rejected.

ESC8**Web enrollment authentication and EPA need hardening**

Severity: Critical · 3 finding(s)

What it is. AD CS web endpoints may expose Windows authentication over HTTP or HTTPS without confirmed Extended Protection.

How it can be abused. An exposed NTLM-capable endpoint can satisfy a relay prerequisite when transport and EPA protections are absent.

How to fix it.

1. Inventory every certsrv, CES, and CEP endpoint and confirm whether it is still required.
2. Disable HTTP bindings; require HTTPS with a valid certificate and redirect or remove legacy listeners.
3. Disable NTLM where feasible and require Extended Protection for Authentication on Windows-authenticated endpoints.
4. Restrict network reachability to approved enrollment clients and monitor endpoint authentication.
5. Retire unused web enrollment roles instead of leaving them partially configured.

How to verify. Recollect endpoint evidence and confirm HTTP is absent, NTLM exposure is reduced, and EPA is Required or otherwise explicitly validated.

ESC11**Certificate requests must require encrypted RPC**

Severity: High · 1 finding(s)

What it is. The CA RPC interface may accept certificate requests without packet privacy when IF_ENFORCEENCRYPTICERTREQUEST is not set.

How it can be abused. Unprotected request traffic can satisfy a relay prerequisite depending on other environmental controls.

How to fix it.

1. Confirm InterfaceFlags live on every issuing CA and identify legacy clients that may be affected.
2. Enable IF_ENFORCEENCRYPTICERTREQUEST during an approved maintenance window.
3. Restart Certificate Services and validate approved enrollment clients.
4. Pair the change with NTLM reduction, SMB/LDAP hardening, and monitoring of failed enrollment requests.

How to verify. Re-read InterfaceFlags and confirm the CA rejects enrollment requests that do not provide the required RPC protection.

ESC2**Any Purpose or no-EKU certificates permit overly broad use**

Severity: High · 1 finding(s)

What it is. A certificate with Any Purpose or no EKU may be accepted for more purposes than intended.

How it can be abused. A broadly usable certificate increases the impact of weak enrollment or identity controls.

How to fix it.

1. Identify the issuing template for each flagged certificate and confirm the business purpose.
2. Replace Any Purpose or empty EKU configuration with only the required application-policy OIDs.
3. Restrict enrollment and add approval where broad certificate use cannot be removed immediately.
4. Revoke and reissue certificates that exceed the documented purpose.

How to verify. Re-export template EKUs and issuance; confirm only documented application policies remain.

ESC4**Non-PKI principals can modify certificate templates**

Severity: High · 1 finding(s)

What it is. Template-control rights can allow a principal to reshape a template into a higher-risk configuration.

How it can be abused. Control over publication, subject-name behavior, EKUs, approval, or security can create an unsafe enrollment path.

How to fix it.

1. Open each flagged template in certtmpl.msc and review its Security descriptor.
2. Remove GenericAll, GenericWrite, WriteDacl, WriteOwner, WriteProperty, and Full Control from non-PKI administrators.
3. Use a dedicated, documented PKI administration group for template changes.
4. Review inherited permissions and the parent Certificate Templates container for the source of access.
5. Compare the final template settings with the approved baseline before republishing.

How to verify. Re-export template ACLs; confirm only approved PKI administrators retain modification rights.

ESC7**CA administrative rights require least privilege**

Severity: High · 1 finding(s)

What it is. Manage CA and Manage Certificates are powerful CA officer and administration rights.

How it can be abused. Unnecessary CA administration can change configuration, approve requests, or manage issued certificates.

How to fix it.

1. Review Manage CA and Manage Certificates assignments on every issuing CA.
2. Remove stale, broad, or non-PKI principals and separate administration from certificate-manager duties.
3. Use dedicated groups with documented membership and privileged-access controls.
4. Review CA officer procedures, approval requirements, and audit logging.

How to verify. Re-export CA security and confirm only approved role groups retain each administrative right.

ESC9/10**Certificate-to-account mapping needs full enforcement**

Severity: High · 1 finding(s)

What it is. Certificates missing or mismatching the SID security extension require strong domain-controller mapping enforcement.

How it can be abused. Weak mapping modes may accept a certificate for an unintended account; unreadable or intended-only policy does not prove protection.

How to fix it.

1. Confirm StrongCertificateBindingEnforcement live on every writable and read-only domain controller.
2. Move all DCs to Full enforcement after completing Microsoft's compatibility review.
3. Identify and reissue certificates that lack the SID security extension where the template should include it.
4. Investigate actionable identity mismatches and document benign mapping cases separately.
5. Monitor certificate-authentication events during and after enforcement rollout.

How to verify. Recollect live DC values and confirm every readable DC reports Full enforcement; validate remaining certificate mappings through approved authentication testing.

Technical Analysis

Methodology

The analysis uses explicit field checks over the supplied scrubbed CSVs. Files are matched by schema and filename hints, not by one fixed client export name. Missing files lower coverage rather than causing clean claims. Counts, categories, and findings are computed programmatically from the current data only.

Data quality & coverage

Certificate rows	16,800; ParseStatus OK: 16,800; Issued: 16,777; Revoked: 15
Identity mapping	present
IdentityMappingStatus	SameIdentity 4196, NoSANUPN 12588, DifferentMappedIdentity 16
Template join	Joined 16800
Issuance signals	ESC6 SAN-attr 10 · ESC3 agent 12 · ESC3 OBO 14 · ESC2 12 · SID missing 12 · SID mismatch real 12
Files supplied	certs=yes, templates=yes, acs=yes, ca=yes, dc=yes, web=yes, hv=yes
DC strong mapping	Full enforcement 6/12; live reads 12; methods WinRM, RemoteRegistry

ESC coverage matrix

ESC	Status	Evidence
ESC1	Critical	1 ESC1-shaped published template(s); 16 requester/SAN mismatch issuance row(s).
ESC2	High	12 Any Purpose/no-EKU issued certificate row(s).
ESC3	Critical	12 enrollment-agent certificate row(s); 14 on-behalf-of row(s).
ESC4	High	1 template(s) flagged with dangerous template-control rights.
ESC5	Critical	4 write/control PKI ACE(s) after excluding enroll-only and CA-host self-control rows.
ESC6	Critical	CA flag true on 1 CA row(s); 10 strong issuance-side SAN-attribute indicator row(s).
ESC7	High	1 CA row(s) marked ESC7Candidate.
ESC8	Critical	4 endpoint row(s); confirmed=1, metadata risk=1, needs EPA check=3.
ESC9/10	High	SID signals=24; DC Full enforcement 6/12 readable row(s); unreadable=0.
ESC11	High	1 CA row(s) marked ESC11Candidate or not enforcing encrypted ICertRequest.

Findings — Likely ESC1 misuse

Finding	Sev	Conf	Evidence
F01-ESC1	Critical	High	6 certificate issuance row(s) on template 'TPL_24152c08622d161118179073' have identity mismatch status DifferentMappedIdentity; 6 joined to template inventory, 6 are authentication-capable, and 6 involve HV/high-value tokens; first=2023-07-01, last=2024-06-30, revoked=0/6. Sample RequestIDs: REQ_3e94596bfd4d8bfe1427236b;REQ_5229509cf6e8e5c183c4367f;REQ_6805b4e213cb4f3331fab340;REQ_a2bac1578097a5f4681d0727;REQ_d37abbc6f8e3ef9d1852f9e1;REQ_ec7fc769ed23736f684d2fe5.
F07-ESC1	High	High	10 certificate issuance row(s) on template 'TPL_24152c08622d161118179073' have identity mismatch status DifferentMappedIdentity; 10 joined to template inventory, 10 are authentication-capable, and 0 involve HV/high-value tokens; first=2024-09-11, last=2026-06-30, revoked=0/10. Sample RequestIDs: REQ_00b9ff103c3f26f7806f6e8e;REQ_076060468943c2acddd2a9da;REQ_161dad265f78734b5e602a76;REQ_408f5ef4179b4e2342857ddd;REQ_45909791af0b7cc1a2af670b;REQ_905f7834e39eb49e2222601a;REQ_a2ab867b7857a1e3855b2c0e;REQ_a901d80cdc86ac0e70e69fc1.

Findings — Suspicious issuance needing validation

Finding	Sev	Conf	Evidence
F02-ESC3	Critical	High	12 certificate row(s) carry the Certificate Request Agent EKU and 14 on-behalf-of row(s) show caller/requester differences; high-value OBO rows: 5; first=2023-09-09, last=2026-06-28, revoked=0/14.
F05-ESC6	Critical	High	10 issued certificate row(s) include SAN request attributes on joined templates that do not allow requester-supplied Subject/SAN; first=2024-04-14, last=2026-01-31, revoked=0/10. Sample RequestIDs: REQ_1f1a1a58b8f75433d9ca5fe9;REQ_34bd8b68a53f21ac62d25b0d;REQ_556fc60639e9f197fd24f65b;REQ_689f40b3f258776425c056cd;REQ_9432c7ebc26dd907f9824278;REQ_a5299656756b727a0167a9e1;REQ_c41fbefef217c4a5ef665533;REQ_d9891de883b0509ca6494c90.
F10-ESC2	High	Medium	12 issued certificate row(s) have Any Purpose or no EKU evidence; high-value involvement: 1; first=2023-09-10, last=2026-06-29, revoked=0/12. Sample RequestIDs: REQ_0400870dcc24161d65d16032;REQ_155ada49c9313f0a1724a2ab;REQ_27778d5448928c2fb4dca318;REQ_28b3e18dfdfeeeaa1670f7bb;REQ_29f5b25ad20fa398bbae9c62;REQ_618a82ed92fe3e8d580b9163;REQ_95868b975d62684058586c6c;REQ_9c11a814aaeb5dff33ea865b.
F13-ESC9-10	High	Medium	SID-extension signals: missing=12, real mismatches=12. 6/12 readable DC row(s) show Full enforcement; unreadable=0.

Findings — Template / PKI posture issue

Finding	Sev	Conf	Evidence
F03-ESC5	Critical	High	4 dangerous PKI-object ACE(s) for PRINCIPAL_46ee1a5d4c288f103379be2e: object types CertificationAuthoritiesContainer, EnrollmentServiceCA, EnrollmentServicesContainer, NTAAuthCertificates; rights include GenericAll, GenericWrite, WriteDacl, WriteOwner. Enroll-only rights were not counted as ESC5 control.
F04-ESC6	Critical	High	CA configuration indicates EDITF_ATTRIBUTESUBJECTALTNAME2 / ESC6_CAConfigFlag is enabled.
F06-ESC8	Critical	High	Web enrollment endpoint COMPUTER_52de4cc85238a4adf90e787: Scheme=http, IsHttp=True, NTLM offered=True, EPA=None, ESC8Confirmed=True, NeedsEpaCheck=False.
F08-ESC1	High	High	1 published template(s) are ESC1-shaped: requester-supplied Subject/SAN, authentication-capable EKU or Any Purpose/no EKU, no manager approval, no authorized signatures, and enrollment rights present. Broad enrollment templates: 1.

Finding	Sev	Conf	Evidence
F09-ESC11	High	High	CA security export indicates encrypted ICertRequest enforcement is not required for CA_b98bb6a076c0a2a3695aeb65 (ESC11Candidate=True, IF_EnforceEncryptICertRequest=False).
F11-ESC4	High	High	PRINCIPAL_ae5f81aaaa93500cdbb6aa32 has dangerous template-control rights on 1 template(s); 1 are published. Sample templates: TPL_b5b309ec40a81cc323da6fb0.
F12-ESC7	High	High	CA security export marks ESC7Candidate=True for CA_b98bb6a076c0a2a3695aeb65; Manage CA principals: ["PRINCIPAL_0d8b92da4bc6c9b143778966"]; Manage Certificates principals: ["PRINCIPAL_48d576affac9d1404843c99"].
F14-ESC8	Medium	Medium	Web enrollment endpoint COMPUTER_e0d161bdf89f70e0a07c8f9: Scheme=https, IsHttp=False, NTLM offered=True, EPA=Unknown, ESC8Confirmed=False, NeedsEpaCheck=True.
F15-ESC8	Medium	Medium	Web enrollment endpoint COMPUTER_86d7aa1bfca862a14d0eb62a: Scheme=https, IsHttp=False, NTLM offered=unknown, EPA=Unknown, ESC8Confirmed=False, NeedsEpaCheck=True.

Evidence trail — High & Critical findings

F01-ESC1 • Critical

Evidence: 6 certificate issuance row(s) on template 'TPL_24152c08622d161118179073' have identity mismatch status DifferentMappedIdentity; 6 joined to template inventory, 6 are authentication-capable, and 6 involve HV/high-value tokens; first=2023-07-01, last=2024-06-30, revoked=0/6. Sample RequestIDs: REQ_3e94596bfd4d8bfe1427236b;REQ_5229509cf6e8e5c183c4367f;REQ_6805b4e213cb4f3331fab340;REQ_a2bac1578097a5f4681d0727;REQ_d37abbc6f8e3ef9d1852f9e1;REQ_ec7fc769ed23736f684d2fe5.

Why it matters: Requester/SAN identity mismatch on an authentication-capable certificate is the core signal for certificate-based impersonation. Issuance alone does not prove the certificate was used.

Validation: Correlate the certificate serials/thumbprints or RequestIDs with DC/Kerberos certificate-authentication logs before claiming confirmed misuse.

Remediation: If unexplained, revoke the certificates and tighten the issuing template's subject/SAN, approval, signature, and enrollment settings.

F02-ESC3 • Critical

Evidence: 12 certificate row(s) carry the Certificate Request Agent ECU and 14 on-behalf-of row(s) show caller/requester differences; high-value OBO rows: 5; first=2023-09-09, last=2026-06-28, revoked=0/14.

Why it matters: Enrollment Agent capability can be legitimate, but it can also enable requesting certificates on behalf of other principals if not tightly restricted.

Validation: Confirm all enrollment agents are authorized and that CA Enrollment Agent restrictions limit which templates and principals they can request for.

Remediation: Restrict enrollment-agent template enrollment, configure CA Enrollment Agent restrictions, and require authorized signatures on sensitive templates.

F03-ESC5 • Critical

Evidence: 4 dangerous PKI-object ACE(s) for PRINCIPAL_46ee1a5d4c288f103379be2e: object types CertificationAuthoritiesContainer, EnrollmentServiceCA, EnrollmentServicesContainer, NTAUTHCertificates; rights include GenericAll, GenericWrite, WriteDacl, WriteOwner. Enroll-only rights were not counted as ESC5 control.

Why it matters: Write/control rights over PKI AD objects can let that principal alter certificate trust, publish or modify templates, or change enrollment-service objects. That is a PKI privilege-escalation path if the principal is not an intended PKI administrator.

Validation: Confirm whether the principal is an approved PKI/tier-0 administrator and whether each listed ACE is intentional.

Remediation: Remove GenericAll/GenericWrite/WriteDacl/WriteOwner/WriteProperty from non-PKI-admin principals on the listed PKI objects; retain only explicit, documented PKI admin groups.

F04-ESC6 • Critical

Evidence: CA configuration indicates EDITF_ATTRIBUTESUBJECTALTNAME2 / ESC6_CAConfigFlag is enabled.

Why it matters: When the CA honors SAN values supplied in request attributes, templates that do not normally allow requester-supplied SAN can still be abused to request certificates for other identities.

Validation: Confirm the CA EditFlags value from the CA host and verify whether any SAN request attributes were accepted.

Remediation: Clear EDITF_ATTRIBUTESUBJECTALTNAME2 and restart the CA service after change-control validation.

F05-ESC6 • Critical

Evidence: 10 issued certificate row(s) include SAN request attributes on joined templates that do not allow requester-supplied Subject/SAN; first=2024-04-14, last=2026-01-31, revoked=0/10. Sample RequestIDs: REQ_1f1a1a58b8f75433d9ca5fe9;REQ_34bd8b68a53f21ac62d25b0d;REQ_556fc60639e9f197fd24f65b;REQ_689f40b3f258776425c056cd;REQ_9432c7ebc26dd907f9824278;REQ_a5299656756b727a0167a9e1;REQ_c41fbebef217c4a5ef665533;REQ_d9891de883b0509ca6494c90.

Why it matters: This is an issuance-side indicator that the CA may have honored SAN values through request attributes rather than template settings.

Validation: Confirm the CA's EDITF_ATTRIBUTESUBJECTALTNAME2 flag and inspect the specific request rows.

Remediation: Disable the CA-wide SAN attribute behavior if not explicitly required and reissue affected certificates as needed.

F06-ESC8 • Critical

Evidence: Web enrollment endpoint COMPUTER_52de4cc85238a4adff90e787: Scheme=http, IsHttp=True, NTLM offered=True, EPA=None, ESC8Confirmed=True, NeedsEpaCheck=False.

Why it matters: AD CS web enrollment can be exposed to NTLM relay risk if HTTP/NTLM is available and EPA/channel binding is absent or unverified.

Validation: Confirm endpoint reachability, authentication schemes, and IIS Extended Protection settings from the web host.

Remediation: Require HTTPS, disable NTLM where possible, require Extended Protection for Authentication, or disable web enrollment if unused.

F07-ESC1 • High

Evidence: 10 certificate issuance row(s) on template 'TPL_24152c08622d161118179073' have identity mismatch status DifferentMappedIdentity; 10 joined to template inventory, 10 are authentication-capable, and 0 involve HV/high-value tokens; first=2024-09-11, last=2026-06-30, revoked=0/10. Sample RequestIDs: REQ_00b9ff103c3f26f7806f6e8e;REQ_076060468943c2acddd2a9da;REQ_161dad265f78734b5e602a76;REQ_408f5ef4179b4e2342857ddd;REQ_45909791af0b7cc1a2af670b;REQ_905f7834e39eb49e2222601a;REQ_a2ab867b7857a1e3855b2c0e;REQ_a901d80cdc86ac0e70e69fc1.

Why it matters: Requester/SAN identity mismatch on an authentication-capable certificate is the core signal for certificate-based impersonation. Issuance alone does not prove the certificate was used.

Validation: Correlate the certificate serials/thumbprints or RequestIDs with DC/Kerberos certificate-authentication logs before claiming confirmed misuse.

Remediation: If unexplained, revoke the certificates and tighten the issuing template's subject/SAN, approval, signature, and enrollment settings.

F08-ESC1 • High

Evidence: 1 published template(s) are ESC1-shaped: requester-supplied Subject/SAN, authentication-capable ECU or Any Purpose/no ECU, no manager approval, no authorized signatures, and enrollment rights present. Broad enrollment templates: 1.

Why it matters: An ESC1-shaped template can allow the enrollee to request a certificate that names another account and can be used for authentication.

Validation: Confirm these templates genuinely require requester-supplied identity fields, and review every principal with Enroll/AutoEnroll rights.

Remediation: Where possible, build subject/SAN from AD. Otherwise require manager approval or authorized signatures and restrict Enroll to tightly controlled groups.

F09-ESC11 • High

Evidence: CA security export indicates encrypted ICertRequest enforcement is not required for CA_b98bb6a076c0a2a3695aeb65 (ESC11Candidate=True, IF_EnforceEncryptICertRequest=False).

Why it matters: If request traffic is not protected, NTLM relay paths to the CA RPC interface may be possible depending on environment controls.

Validation: Confirm InterfaceFlags on the CA and whether ICertRequest encryption is enforced.

Remediation: Enable encrypted ICertRequest enforcement and restart the CA service after validation.

F10-ESC2 · High

Evidence: 12 issued certificate row(s) have Any Purpose or no ECU evidence; high-value involvement: 1; first=2023-09-10, last=2026-06-29, revoked=0/12. Sample RequestIDs: REQ_0400870dcc24161d65d16032;REQ_155ada49c9313f0a1724a2ab;REQ_27778d5448928c2fb4dca318;REQ_28b3e18dfdfceeeaa1670f7bb;REQ_29f5b25ad20fa398bbae9c62;REQ_618a82ed92fe3e8d580b9163;REQ_95868b975d62684058586c6c;REQ_9c11a814aaeb5dff33ea865b.

Why it matters: Any Purpose or no-EKU certificates may be usable for client authentication depending on chain and policy context.

Validation: Confirm intended EKUs and whether the certificate chain allows client authentication.

Remediation: Remove Any Purpose/no-EKU issuance unless explicitly required; issue workload-specific EKUs only.

F11-ESC4 · High

Evidence: PRINCIPAL_ae5f81aaaa93500cddb6aa32 has dangerous template-control rights on 1 template(s); 1 are published. Sample templates: TPL_b5b309ec40a81cc323da6fb0.

Why it matters: A principal that can modify a certificate template can potentially reshape it into an ESC1-capable template and then request authentication-capable certificates.

Validation: Confirm whether the principal is an intended template/PKI administrator. Recurring control across many templates may be normal PKI administration, but should be explicitly validated.

Remediation: Remove Write/Full Control/WriteDacl/WriteOwner from non-PKI-admin principals on certificate templates; use a dedicated PKI admin group.

F12-ESC7 · High

Evidence: CA security export marks ESC7Candidate=True for CA_b98bb6a076c0a2a3695aeb65; Manage CA principals: ["PRINCIPAL_0d8b92da4bc6c9b143778966"]; Manage Certificates principals: ["PRINCIPAL_48d576affac9d1404843c99"].

Why it matters: Manage CA and Manage Certificates can permit CA configuration changes or request approvals that enable certificate abuse.

Validation: Confirm every listed principal is an intended CA administrator/officer.

Remediation: Remove Manage CA / Manage Certificates from non-authorized principals and use dedicated CA admin/officer groups.

F13-ESC9-10 · High

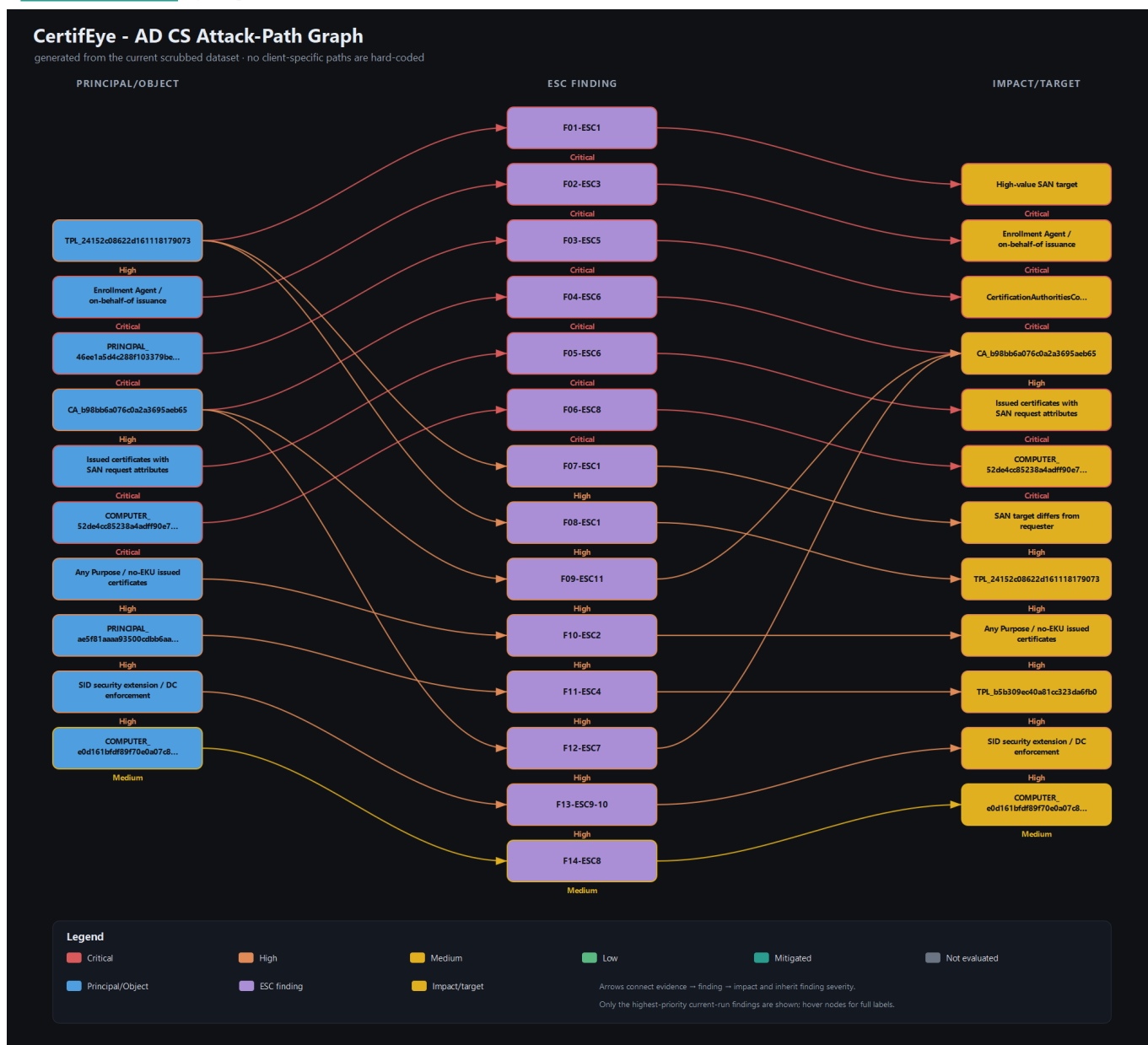
Evidence: SID-extension signals: missing=12, real mismatches=12. 6/12 readable DC row(s) show Full enforcement; unreadable=0.

Why it matters: Weak certificate mapping is exploitable only when domain controllers accept weak mappings for certificates missing or mismatching the SID security extension.

Validation: Confirm StrongCertificateBindingEnforcement live on every DC and correlate any suspicious certificates to authentication logs.

Remediation: Set StrongCertificateBindingEnforcement=2 on all DCs and reissue certificates with the SID security extension where applicable.

Attack-path graph



Appendix — assumptions, token model, limitations

- All inputs are assumed scrubbed. Tokens such as PRINCIPAL_x, HV_PRINCIPAL_x, GROUP_x, COMPUTER_x, TEMPLATE_x, CA_x, and X500_x are anonymized; broad/default labels are intentionally preserved for risk scoring.
- No real identities were inferred or reverse-mapped.
- Issued-certificate evidence proves issuance, not authentication or use. Confirmation requires DC/Kerberos certificate-authentication logs.
- If an ESC area is marked Not evaluated, the corresponding input file was not supplied or did not contain recognizable columns.
- All remediation is advisory guidance for a PKI administrator to validate and apply in a maintenance window.